

Nhiệm vụ 3: Thực hiện tấn công và phân tích sự kiện

Phần 1: Thực hiện tấn công

Kịch bản 1: Thực hiện Brute-force Attack

Bước 1: Tại máy SecOnion

Update rule để cập nhật cảnh báo cho SSH brute-force

```
[sudo] password for quyetnt:
quyetnt@quyetnt-virtual-machine:~$ sudo nano /etc/nsm/rules/local.rules
quyetnt@quyetnt-virtual-machine:~$ sudo rule-update
Thứ sáu, 06 Tháng ba năm 2026 06:14:52 UTC
Backing up current local_rules.xml file.
Cleaning up local_rules.xml backup files older than 30 days.
Backing up current downloaded.rules file before it gets overwritten.
Cleaning up downloaded.rules backup files older than 30 days.
Backing up current local.rules file before it gets overwritten.
Cleaning up local.rules backup files older than 30 days.
Running PulledPork.
https://github.com/shirkdog/pulledpork

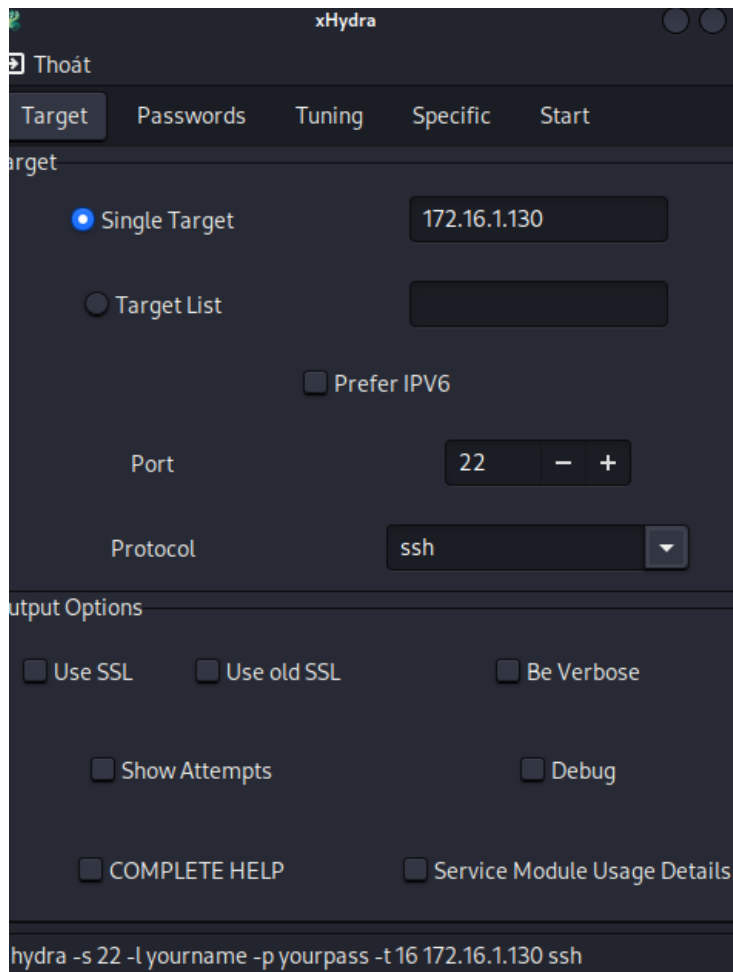
      _____
     /  _  _  \  )
    /  _  _  \  )
   /  _  _  \  )
  /  _  _  \  )
 /  _  _  \  )
/  _  _  \  )
@_/_/_/_/_/_/_/ 66\  Copyright (C) 2009-2017 JJ Cummings, Michael Shirk
                    and the PulledPork Team!
                    Rules give me wings!

~~~~~
Checking latest MD5 for emerging.rules.tar.gz....
Rules tarball download of emerging.rules.tar.gz....
```

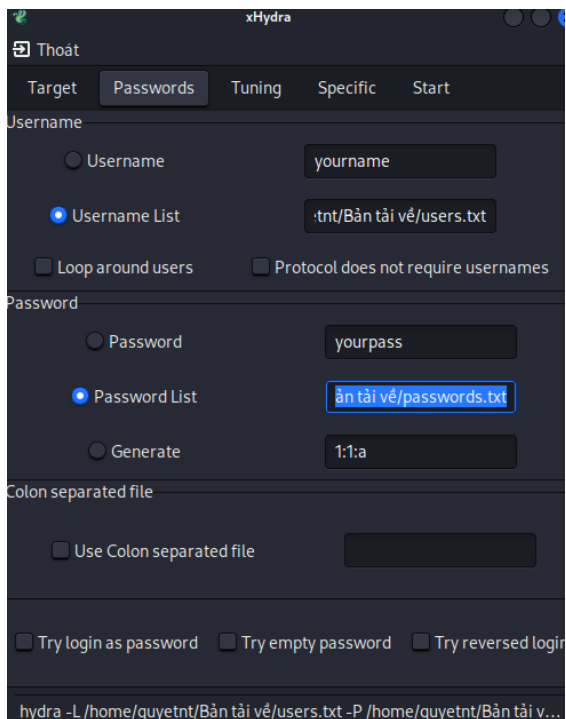
Bước 2: Trên máy Kali

Dùng công cụ xHydra để thực hiện SSH Brute-force Attack

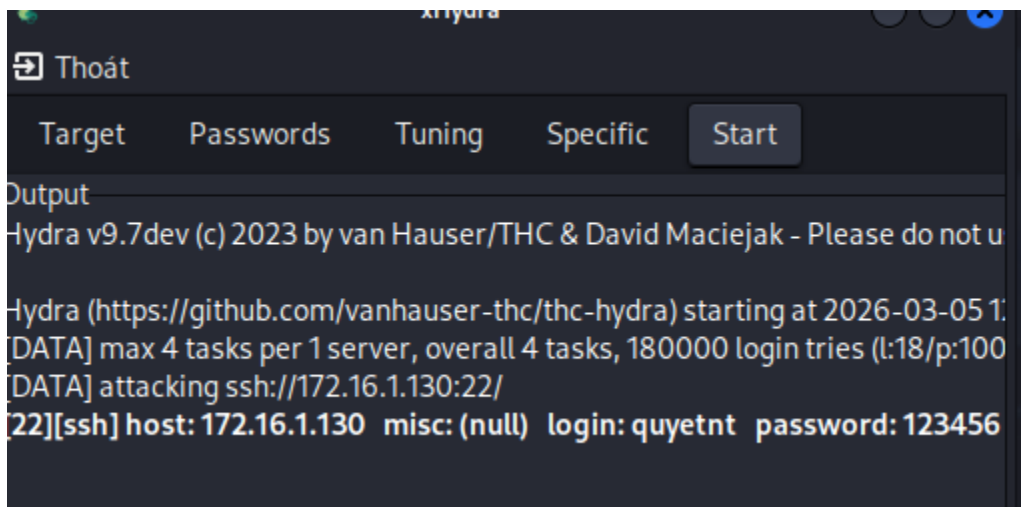
Tại Tab Target



Tại tab password dùng file username và password lấy từ github về để thực hiện bruteforce



Sang Start và nhấn Start rồi đợi kết quả



Dò quét thành công username: quietnt ; password: 123456

Bước 3: Quay về Seconion, vào Squert để kiểm tra

Thực hiện download file UDPFloodattack.py từ

https://github.com/mason2211/TTATTT_2021/blob/main/UDPFloodattack.py

File này dùng để:

Gửi gói tin UDP liên tục: File này tạo ra một vòng lặp while True để gửi các gói tin theo giao thức UDP đến địa chỉ IP mục tiêu một cách nhanh nhất có thể.

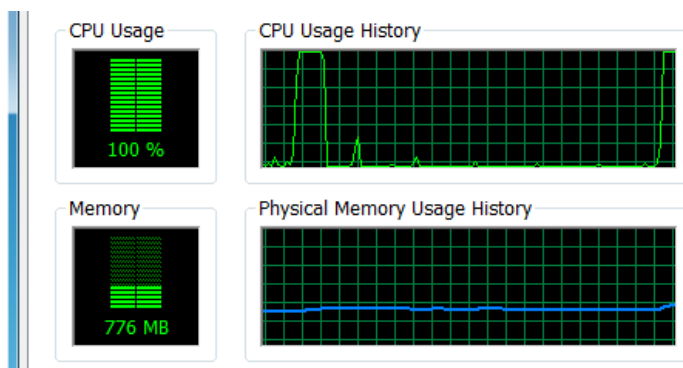
Làm tràn ngập băng thông và tài nguyên: Bằng cách gửi lượng dữ liệu lớn (size) liên tục, nó cố gắng chiếm dụng toàn bộ băng thông mạng hoặc tài nguyên xử lý của mục tiêu

Tiếp theo, vào Terminal thực hiện lệnh sau:

```
(quyetnt@quyetnt)~[~/Bản tải về]
$ python UDPFloodattack.py 172.16.1.130
Attacking 172.16.1.130 on random ports for unlimited time with a size of 1024 bytes.
```

Bước 4: Quay lại

Win7 kiểm tra



Dos thành công Win7 CPU usage: 100%

Bước 5: Vào máy Seconion kiểm tra

254 0 1 1 05:57:41 UDP Flood DoS Detected 2527045 17 93.382%

alert udp any any -> any any (msg:"UDP Flood DoS Detected"; dsiz>1000; threshold: type threshold, track by_src, count 100, seconds 1; sid:2527045; rev:1;)

file: downloaded.rules:67381

☒ CATEGORIZE 254 EVENT(S) CREATE FILTER: src dst both

QUEUE	ACTIVITY	LAST EVENT	SOURCE	AGE	COUNTRY	DESTINATION	AGE	COUNTRY
254		2026-03-06 05:57:41	172.16.1.129	25	RFC1918 (.lo)	172.16.1.130	26	RFC1918 (.lo)

IOSSEC11 Listed

Cảnh báo phát hiện DOS thành công

Kịch bản 3: SQL injection

Bước 1: Trên máy Kali mở FireFox

Nhập địa chỉ máy win7

Not Secure http://172.16.1.130/dvwa/index.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. This is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possibly could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any internet facing servers**, as they will be compromised. It is recommended using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed.

Home

- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API

Vào trình duyệt và truy cập DVWA , chọn kiểm thử SQL injection

Tại trường UserID nhập 1, thì có kết quả như sau:

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

Bây giờ chèn câu lệnh SQL : “'or 1=1 -- -” vào trường UserID, kết quả trả về:

Vulnerability: SQL Injection

User ID:

ID: ' or 1=1 -- -
First name: admin
Surname: admin

ID: ' or 1=1 -- -
First name: Gordon
Surname: Brown

ID: ' or 1=1 -- -
First name: Hack
Surname: Me

ID: ' or 1=1 -- -
First name: Pablo
Surname: Picasso

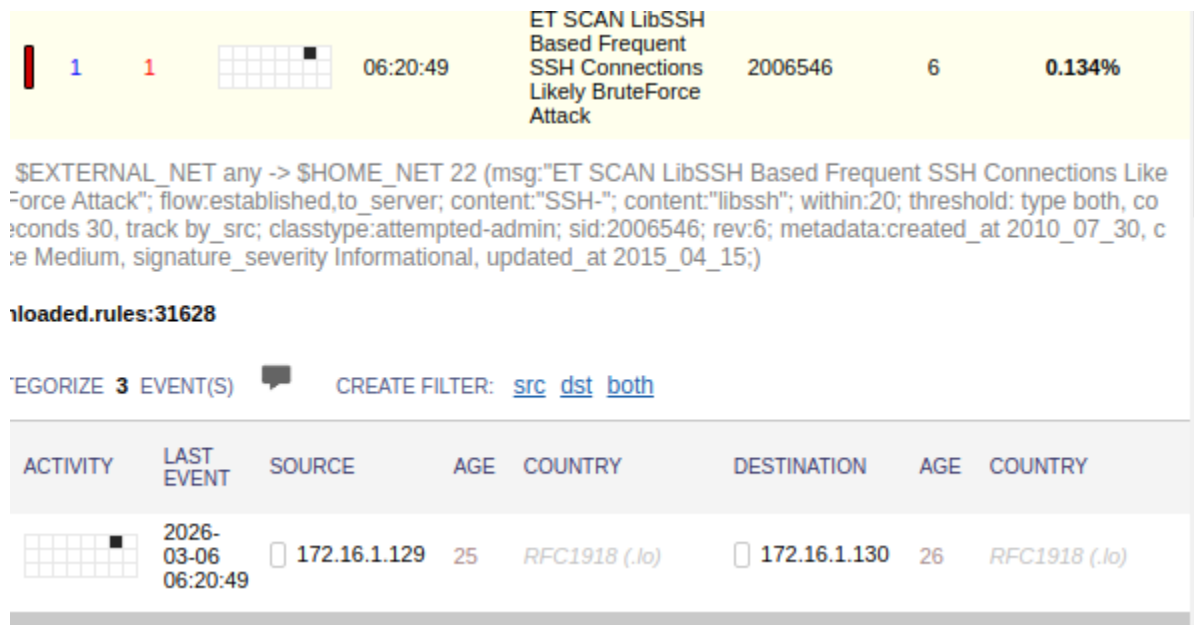
ID: ' or 1=1 -- -
First name: Bob
Surname: Smith

Với kết quả trên xác định tiêm SQL thành công

Bước 2: Vào seconion giám sát

Phần 2: Phân tích sự kiện

1. Sự kiện SSH bruteforce



Tên cảnh báo: ET SCAN LibSSH Based Frequent SSH Connections Likely BruteForce Attack

Rule ID: 2006546

Thời gian: 06:20:49 – 06/03/2026

Thông tin sự kiện

Nguồn (Source IP): 172.16.1.129

Đích (Destination IP): 172.16.1.130

Cổng dịch vụ: 22 (SSH)

Phân tích

IDS phát hiện nhiều kết nối SSH được thực hiện liên tục trong thời gian ngắn.

Mã SID 2006546 xác định đây là hành vi quét dựa trên thư viện libssh. Đây là bằng chứng cho thấy việc sử dụng công cụ tự động thay vì con người đăng nhập.

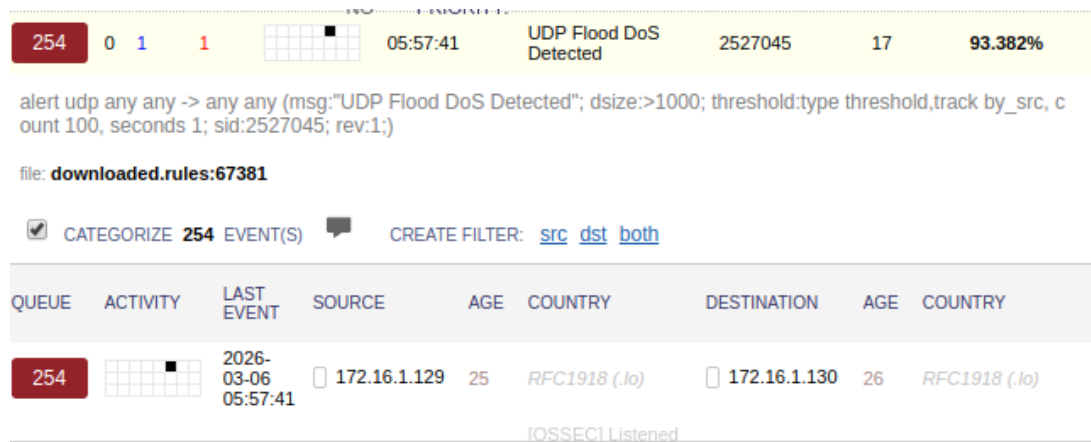
Điều này cho thấy dấu hiệu của tấn công Brute Force nhằm đoán mật khẩu SSH.

Mục tiêu của tấn công

Truy cập trái phép vào máy chủ thông qua SSH.

Chiếm quyền điều khiển hệ thống nếu đoán được mật khẩu.

2.Sự kiện DDos



Tên cảnh báo: UDP Flood DoS Detected

Rule ID: 2527045

Thời gian: 05:57:41 – 06/03/2026

Thông tin sự kiện

- Nguồn (Source IP): 172.16.1.129
- Đích (Destination IP): 172.16.1.130
- Giao thức: UDP
- Số lượng sự kiện: 254 events

Phân tích

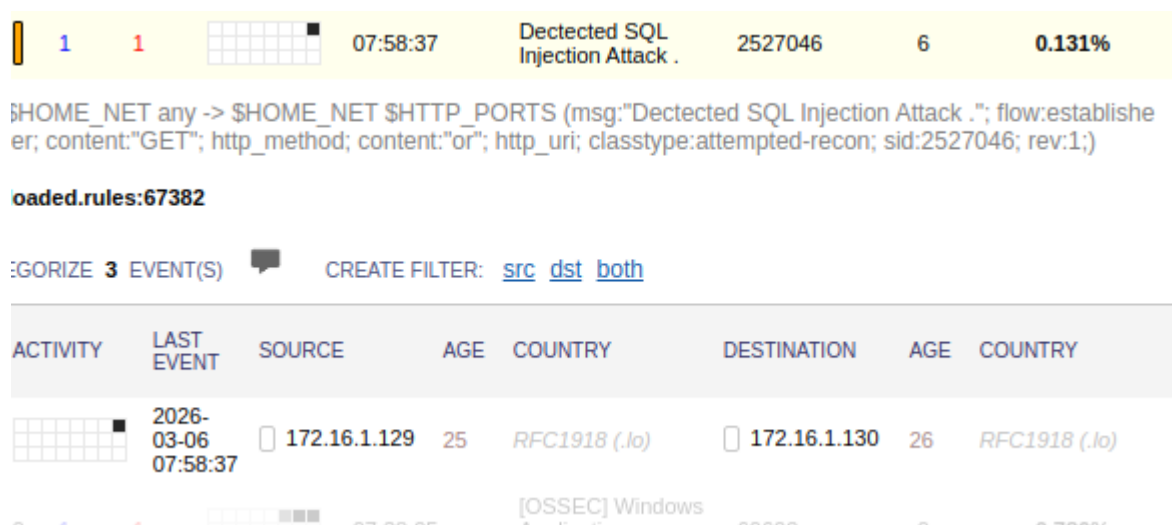
- IDS phát hiện số lượng lớn gói tin UDP có kích thước lớn gửi liên tục từ cùng một địa chỉ IP.

- Khi số lượng gói tin vượt quá ngưỡng cho phép trong một khoảng thời gian ngắn, hệ thống xác định đây là UDP Flood Attack.

Mục đích của tấn công

- Làm quá tải bằng thông mạng.
- Làm cạn tài nguyên hệ thống của máy chủ.
- Khiến dịch vụ mục tiêu bị gián đoạn hoặc ngừng hoạt động.

3.Sự kiện SQL injection



Tên cảnh báo: Detected SQL Injection Attack

Rule ID: 2527046

Thời gian: 07:58:37 – 06/03/2026

Thông tin sự kiện

- Nguồn (Source IP): 172.16.1.129
- Đích (Destination IP): 172.16.1.130
- Giao thức: HTTP
- Phương thức: GET

Phân tích

- Hệ thống IDS phát hiện chuỗi truy vấn HTTP có dấu hiệu của SQL Injection.
- Payload trong URI có chứa chuỗi "or", thường được sử dụng trong các truy vấn SQL độc hại.
- Kiểu tấn công này thường nhằm mục đích:
 - Bỏ qua cơ chế xác thực (Authentication Bypass)
 - Truy xuất trái phép dữ liệu trong cơ sở dữ liệu
 - Kiểm tra lỗ hổng của ứng dụng web